

SmartKrishi বাস্তবায়িত নিরাপত্তা ফিচারসমূহ

ফিচার কীভাবে কাজ করে, কীভাবে বাস্তবায়ন করা হয়েছে এবং Faculty-কে
কীভাবে দেখাবেন

Computer Security Project Report

প্রস্তুতের তারিখ: ৪ অক্টোবর ২০২৬

১. সারসংক্ষেপ

SmartKrishi একটি multi-role কৃষি ব্যবস্থাপনা application। এতে শুধু login নয়, database, form submission, browser output, file upload, session, MFA, activity monitoring এবং security testing স্তরে প্রতিরক্ষা যোগ করা হয়েছে।

অবস্থা	ফিচার
সম্পূর্ণ বাস্তবায়িত	RBAC, ownership control, MFA, password hashing, brute-force protection, SQL injection protection, CSRF, XSS protection, secure upload, ClamAV, activity monitoring, security logging, secure session, security headers, AI quota এবং OWASP ZAP testing
আংশিক / Troubleshooting	Wazuh Cloud custom SmartKrishi alert visualization
প্রস্তুত, কিন্তু active নয়	ModSecurity + OWASP Core Rule Set

Faculty presentation-এর প্রধান তিনটি ফিচার: (১) Centralized RBAC + ownership + activity monitoring, (২) Mandatory Admin MFA + brute-force protection, এবং (৩) Secure upload + ClamAV malware scanning।

২. Centralized RBAC

Major

কীভাবে কাজ করে

RBAC বা Role-Based Access Control user-এর role অনুযায়ী page ও operation ব্যবহারের অনুমতি নির্ধারণ করে। SmartKrishi-তে Admin, Farmer, Customer, Supplier, Labour এবং Agrologist-এর জন্য আলাদা access policy রয়েছে।

কীভাবে বাস্তবায়ন করা হয়েছে

- Shared security bootstrap route অনুযায়ী প্রয়োজনীয় role যাচাই করে।
- `require_login()` login ছাড়া protected page ব্যবহার বন্ধ করে।
- `require_role()` ভুল role হলে HTTP 403 response দেয়।
- Admin, Farmer, Supplier এবং analytics routes centralized policy দিয়ে protected।

Faculty demo

1. Farmer বা Customer account দিয়ে login করুন।
2. `/admin/admin.php` URL খুলুন।
3. Access denied/403 দেখান এবং security log-এ `authorization.role_denied` দেখান।

৩. Ownership Control

Major

কীভাবে কাজ করে

Role একই হলেও একজন user যেন অন্য user-এর data পরিবর্তন করতে না পারে, সেটিই ownership control। এটি horizontal privilege escalation প্রতিরোধ করে।

বাস্তবায়ন

Order বা supply update query-তে resource ID-এর পাশাপাশি logged-in user ID ব্যবহার করা হয়। যেমন: `WHERE order_id = ? AND farmer_id = ?`। মালিকানা না মিললে update হয় না এবং denial log হয়।

Faculty demo

দুইটি Farmer/Supplier account ব্যবহার করুন। প্রথম account-এর resource ID দ্বিতীয় account দিয়ে update করার চেষ্টা করুন। Request reject হওয়া এবং `authorization.ownership_denied` event দেখান।

8. TOTP Multi-Factor Authentication

Major

কীভাবে কাজ করে

Password-এর পাশাপাশি authenticator app-এর প্রতি ৩০ সেকেন্ডে পরিবর্তিত ৬-digit code প্রয়োজন হয়। তাই password ফাঁস হলেও phone ছাড়া login করা কঠিন।

Password (যা user জানে) + Authenticator code (যা user-এর কাছে আছে)

বাস্তবায়ন

- Admin-এর জন্য MFA বাধ্যতামূলক; অন্য role-এর জন্য optional।
- TOTP secret AES-256-GCM দিয়ে encrypted অবস্থায় database-এ থাকে।
- ৮টি one-use recovery code তৈরি হয় এবং hash আকারে সংরক্ষিত হয়।
- একই ৩০-second code দ্বিতীয়বার ব্যবহার বন্ধ করতে counter রাখা হয়।
- ভুল MFA attempt rate limited এবং lock হলে ১০ মিনিটের countdown দেখা যায়। Countdown শেষে page auto-refresh হয়, তবে unlock decision server নেয়।

Faculty demo

1. Admin password দিয়ে login করুন।
2. Authenticator code challenge দেখান।
3. সঠিক code দিয়ে successful login দেখান।
4. Demo account-এ পাঁচবার ভুল code দিয়ে ১০-minute countdown দেখান।

৫. Password ও Brute-Force Protection

Major

কীভাবে কাজ করে

Password plain text রাখা হয় না। Hash থেকে original password সহজে বের করা যায় না। Rate limiting automated password guessing ধীর করে।

বাস্তবায়ন

- PHP support করলে Argon2id, অন্যথায় bcrypt।
- `password_verify()` দিয়ে password যাচাই।
- পুরোনো hash successful login-এর পর upgrade হতে পারে।
- Hashed identifier ও IP অনুযায়ী failed attempts database-এ রাখা হয়।
- Defaultভাবে ১৫ মিনিটে পাঁচটি failed password attempt হলে login temporarily block হয়।

Faculty demo

একই phone number দিয়ে পাঁচবার ভুল password দিন। Rate-limit message এবং `authentication.rate_limited` log দেখান। Database-এ password field hash আকারে আছে দেখাতে পারেন, কিন্তু hash copy করে প্রকাশ করবেন না।

৬. Activity ও Anomaly Monitoring

Major / Unique

কীভাবে কাজ করে

Business activity-এর threshold-based rules অস্বাভাবিক আচরণ শনাক্ত করে। এটি machine learning নয়; explainable rules-based prototype।

বাস্তবায়ন

- ১০ মিনিটে একই ধরনের পাঁচটি authorization denial alert তৈরি করে।
- Supply price ৫০% বা বেশি পরিবর্তন অথবা ১০ মিনিটে ১০টি price update review alert তৈরি করে।
- ১০ মিনিটে ১০টি order-status change alert তৈরি করে।
- Crop Doctor ও Insect Identification একই per-user AI quota ব্যবহার করে।
- Admin Security Activity page গত ২৪ ঘণ্টার সর্বশেষ ২০০ alerts দেখায়।

Faculty demo

```
C:\xampp\php\php.exe D:\farming_management_system\security\activity_test.php
```

Expected: PASS: 9 detection, boundary and expiry checks। এরপর Admin → Security Activity page দেখান।

৭. SQL Injection Protection

কীভাবে কাজ করে

Prepared query SQL command এবং user data আলাদা রাখে। ফলে input SQL syntax হিসেবে execute না হয়ে data হিসেবে ব্যবহৃত হয়।

বাস্তবায়ন

PDO native prepared statements ও parameterized execution ব্যবহার করা হয়েছে:

```
$stmt = $pdo->prepare('SELECT * FROM users WHERE phone_number = ? LIMIT 1');  
$stmt->execute([$phoneNumber]);
```

Faculty demo

Login phone field-এ harmless test payload ' OR '1'='1 দিন। Authentication bypass হবে না। Code-এ prepare() এবং execute() দেখান।

৮. CSRF Protection

কীভাবে কাজ করে

প্রতিটি state-changing request-এ session-bound, unpredictable ২৫৬-bit token প্রয়োজন। Attacker browser cookie ব্যবহার করতে পারলেও token জানতে পারে না।

বাস্তবায়ন

- `random_bytes(32)` থেকে token তৈরি।
- POST, PUT, PATCH ও DELETE request-এ token যাচাই।
- `hash_equals()` দিয়ে constant-time comparison।
- Missing/invalid token হলে HTTP 403 এবং `csrf.violation` log।

Faculty demo

1. Data-changing form খুলুন।
2. DevTools → Elements-এ `_csrf_token` field খুঁজুন।
3. Value পরিবর্তন বা element delete করে submit করুন।
4. HTTP 403 এবং "Invalid or expired security token" দেখান।

৯. XSS Protection ও Security Headers

কীভাবে কাজ করে

Output encoding user input-কে executable HTML/JavaScript না বানিয়ে text হিসেবে দেখায়।
Browser headers অতিরিক্ত defence-in-depth দেয়।

বাস্তবায়ন

- `htmlspecialchars(..., ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8')` ভিত্তিক `e()` helper।
- Content-Security-Policy, `nosniff`, SAMEORIGIN frame policy, Referrer-Policy ও Permissions-Policy।
- Camera, microphone ও geolocation permission বন্ধ।

Faculty demo

User-visible input field-এ `<script>alert(1)</script>` দিন। Popup না হয়ে text বা rejected input হওয়া দেখান। DevTools → Network → Response Headers-এ security headers দেখান।

সীমাবদ্ধতা: Existing inline scripts/styles-এর compatibility-এর জন্য CSP-তে এখনো `'unsafe-inline'` আছে। তাই output encoding প্রধান XSS control।

১০. Secure Upload ও ClamAV Major

Upload → Size → Extension → MIME → Image structure → Quarantine → ClamAV
→ Random filename

বাস্তবায়ন

- Maximum size ৫ MB।
- শুধু JPG, JPEG, PNG, GIF এবং WebP extension ও matching MIME type।
- `getimagesize()` দিয়ে actual image structure যাচাই।
- Public storage-এর আগে private quarantine।
- ClamAV clean result ছাড়া permanent storage নয়; scanner unavailable হলে fail-closed।
- `random_bytes(20)` থেকে ৪০-character random filename।
- Invalid/infected file delete এবং security event log।

Faculty demo

1. `test.php` upload করে rejection দেখান।
2. Text file-এর নাম `fake.jpg` করে upload করুন; MIME/image validation reject করবে।
3. ৫ MB-এর বড় file rejection দেখান।
4. Valid image upload করে random stored filename দেখান।

সতর্কতা: Real malware ব্যবহার করবেন না। Faculty demo-তে PHP, fake JPG এবং oversized file যথেষ্ট।

১১. Security Logging

কীভাবে কাজ করে

Security events JSON Lines format-এ লেখা হয়; প্রতিটি line একটি independent JSON object, যা SIEM সহজে parse করতে পারে।

বাস্তবায়ন

Log: D:\farming_management_system\storage\logs\security.jsonl

Failed login, rate limit, MFA, CSRF, role/ownership denial, upload rejection, malware এবং activity events log হয়। Password, API key, MFA secret/code ও raw login identifier log হয় না। Login identifier SHA-256 hash করা হয়।

Faculty demo

```
Get-Content "D:\farming_management_system\storage\logs\security.jsonl" -Wait -Tail 10
```

Command চালু রেখে wrong login, unauthorized page এবং invalid CSRF test করুন। নতুন structured events live দেখান।

১২. Secure Session Management

বাস্তবায়ন

- Strict session mode এবং cookie-only sessions।
- HttpOnly cookie JavaScript থেকে session cookie পড়া কঠিন করে।
- SameSite=Lax cross-site request-এর ঝুঁকি কমায়।
- HTTPS হলে Secure cookie।
- Login/MFA completion ও নির্দিষ্ট সময় পর session ID regeneration।

Faculty demo

DevTools → Application/Storage → Cookies-এ session cookie-এর HttpOnly ও SameSite attributes দেখান। Login-এর আগে ও পরে session identifier পরিবর্তন হয়েছে কিনা দেখাতে পারেন; value প্রকাশ করবেন না।

১৩. Sensitive File, Upload Execution ও Secret Protection

বাস্তবায়ন

- Root `.htaccess` directory listing বন্ধ করে।
- `.env`, `.git`, `security` ও `storage` web access block।
- Upload directory-তে executable scripts চলা বন্ধ।
- API keys, database credentials এবং MFA encryption key `.env` -এ; Git ignore করা।

Faculty demo

Browser থেকে `/.env`, `/.git/` বা `/storage/logs/security.jsonl` খোলার চেষ্টা করুন। Access denied/404 হওয়া দেখান। কোনো secret screen-এ দেখাবেন না।

১৪. AI Request Quota Protection

কীভাবে কাজ করে

AI API ব্যয়, abuse ও resource exhaustion নিয়ন্ত্রণ করে। Crop Doctor ও Insect Identification-এর quota shared, তাই endpoint পরিবর্তন করে limit bypass করা যায় না।

বাস্তবায়ন

- প্রতি user ১০ মিনিটে সর্বোচ্চ ১০ attempts।
- Rolling ২৪ ঘণ্টায় সর্বোচ্চ ৫০ accepted attempts।
- Invalid upload-ও attempt হিসেবে গণনা হয়।
- Limit ছাড়ালে external API call-এর আগেই HTTP 429।
- Quota storage unavailable হলে fail-closed HTTP 503।

Faculty demo

`security/activity_test.php` test output দেখান অথবা controlled demo account দিয়ে threshold পর্যন্ত request করে HTTP 429 দেখান। Production API key বা বেশি paid request ব্যবহার করবেন না।

১৫. OWASP ZAP Security Testing

কীভাবে কাজ করে

ZAP web application crawl করে common vulnerability payload দিয়ে SQL injection, XSS, missing headers এবং অন্যান্য web weaknesses পরীক্ষা করে। এটি runtime protection নয়; testing tool।

বাস্তবায়ন

- ZAP 2.17.0 ও Java 17 local security tools directory-তে installed।
- Automation plan public attack surface scan করে।
- সর্বশেষ scan-এ ৮৪টি URL discovered; confirmed SQL injection বা XSS alert পাওয়া যায়নি।
- Report: `storage/reports/zap-report.html`

Faculty demo

HTML report খুলে URL count, alert severity এবং SQL injection/XSS results দেখান। শুধু local test data-তে active scan চালাবেন।

১৬. Wazuh SIEM Integration - আংশিক

লক্ষ্য

SmartKrishi JSON security logs Windows Agent-এর মাধ্যমে Wazuh Cloud-এ পাঠিয়ে centralized alert, threat hunting, endpoint inventory, SCA ও vulnerability monitoring করা।

যা সম্পন্ন

- Wazuh Cloud environment এবং Windows Agent enrollment।
- Agent active হওয়া এবং SmartKrishi `security.json1` file analysis confirmation।
- Custom rules 100100-100107 manager-এ visible।
- Endpoint inventory, vulnerability detection এবং SCA capability উপলভ্য।

বর্তমান সীমাবদ্ধতা

SmartKrishi custom events Threat Hunting-এ নির্ভরযোগ্যভাবে দেখা যায়নি; agent একসময় server unavailable ছিল এবং Cloud Ruleset Test inconsistent ছিল। তাই এটিকে **configured but under troubleshooting** বলবেন, fully working custom SIEM alerting নয়।

Faculty demo

Agents page-এ endpoint, Rules page-এ custom rule IDs, Vulnerability/SCA pages এবং local JSON logs দেখান। Custom alert result না এলে সীমাবদ্ধতা সংভাবে ব্যাখ্যা করুন।

১৭. ModSecurity + OWASP CRS - Prepared, Active নয়

লক্ষ্য

Apache-এর সামনে Web Application Firewall হিসেবে malicious request detect/block করা।
OWASP CRS common SQL injection, XSS, traversal ও protocol attacks-এর signatures দেয়।

বর্তমান অবস্থা

OWASP CRS 4.29.0 এবং SmartKrishi configuration প্রস্তুত; audit log path-ও নির্ধারিত। কিন্তু
বর্তমান XAMPP Apache 2.4.58 Win64 VS17-এর compatible trusted ModSecurity module না
থাকায় WAF load করা হয়নি। ভুল binary Apache বন্ধ করে দিতে পারে।

Faculty-কে কী বলবেন

এটিকে future improvement/prepared configuration বলবেন, implemented active protection
নয়। প্রথমে DetectionOnly mode, log tuning, তারপর blocking mode প্রয়োজন।

১৮. Faculty Live Demonstration Plan

সময়	Demo	Expected result
১ মিনিট	Farmer account দিয়ে Admin URL	403 + role-denied log
২ মিনিট	Admin password + authenticator code	Two-step login; ভুল attempts-এ countdown
১ মিনিট	Login-এ SQL payload	Bypass হবে না
১ মিনিট	CSRF token পরিবর্তন	HTTP 403 + csrf.violation
১ মিনিট	XSS payload	Script execute হবে না
২ মিনিট	PHP/fake JPG/valid image upload	Invalid reject; valid random filename
১ মিনিট	Live security.jsonl tail	Structured events
১ মিনিট	Activity test ও Admin dashboard	PASS output + alerts
১ মিনিট	ZAP report	Scan evidence

১৯. সংক্ষিপ্ত উপস্থাপনা বক্তব্য

“SmartKrishi-তে আমরা defence-in-depth security architecture বাস্তবায়ন করেছি। Centralized RBAC ও ownership control unauthorized access প্রতিরোধ করে। Administrator-এর জন্য encrypted TOTP MFA এবং brute-force rate limiting রয়েছে। Database operations prepared queries ব্যবহার করে, state-changing forms CSRF token যাচাই করে, এবং output encoding ও browser headers XSS ঝুঁকি কমায়। Uploaded images public storage-এর আগে size, extension, MIME ও structure validation অতিক্রম করে, quarantine-এ ClamAV scan হয় এবং random filename-এ সংরক্ষিত হয়। Activity monitoring business anomalies শনাক্ত করে এবং সব গুরুত্বপূর্ণ ঘটনা privacy-aware JSON security logs-এ লেখা হয়। Applicationটি OWASP ZAP দিয়েও পরীক্ষা করা হয়েছে।”

২০. গুরুত্বপূর্ণ সততা ও নিরাপত্তা নোট

- Wazuh custom alert visualization এখনো troubleshooting পর্যায়ে।
- ModSecurity/CRS configuration প্রস্তুত, কিন্তু active নয়।
- ZAP scan vulnerability না পাওয়ার অর্থ application কখনো vulnerable নয় - এমন নিশ্চয়তা নয়।
- Real malware, production data বা অন্যের account দিয়ে demonstration করবেন না।
- Demo account-এ দুর্বল password থাকলে presentation শেষে পরিবর্তন বা account delete করুন।
- API keys, password hashes, MFA QR/secret ও recovery codes screen-এ প্রকাশ করবেন না।